

Project	Inventory Name	Priority	Component	License	Vulnerabilities	Tasks	Alerts	Status	Created On
ePortal 1.5	Apache ActiveMQ 5.4.0 (Apache-2.0)	P3 - Low	① apache-activemq 5.4	① Apache-2.0	3 0 8 1 29			Approved	9/9/2017
ePortal 1.5	Apache Commons BeanUtils 1.7.0 (Apache-2.0)	P3 - Low	① apache-commons-beanutils 1.7	① Apache-2.0	0 0 0 0 18			Approved	9/9/2017
ePortal 1.5	Apache Commons Codec 1.3 (Apache-2.0)	P3 - Low	① apache-jakarta-commons-codec 1.3	① Apache-2.0	None			Approved	9/9/2017
ePortal 1.5	Apache Commons IO 1.4 (Apache-2.0)	P3 - Low	① apache-jakarta-commons-io 1.4	① Apache-2.0	None			Approved	9/9/2017
ePortal 1.5	Apache Commons Lang 2.3 (Apache-2.0)	P3 - Low	① apache-jakarta-commons-lang 2.3	① Apache-2.0	None			Approved	9/9/2017
ePortal 1.5	Apache Struts 2.3.20 (Apache-2.0)	P1 - High	① apache-struts 2.3.20	① Apache-2.0	9 0 4 0 35			Rejected	2/6/2019
ePortal 1.5	bzip2 1.0.3 (BSD-1-Clause)	P1 - High	① bzip2 1.0.3	① BSD-1-Clause	1 1 0 0 29			Rejected	2/6/2019
ePortal 1.5	cglib 2.1.3 (Apache-2.0)	P3 - Low	① cglib-cglib 2.1	① Apache-2.0	None			Approved	9/9/2017
ePortal 1.5	dom4j 1.6.1 (dom4j License)	P3 - Low	① dom4j 1.6.1	① dom4j License	None			Rejected	9/9/2017
ePortal 1.5	eportal 1.5 (Apache-2.0)	P3 - Low	① eportal 1.5	① Apache-2.0	None			Approved	2/6/2019
ePortal 1.5	expat 1.95.8 (MIT)	P1 - High	① expat 1.95.8	① MIT	1 1 0 0 15			Rejected	2/6/2019
ePortal 1.5	hibernate 3.1.3 (LGPL-2.1)	P2 - Medium	① hibernate 3.1.3	① LGPL-2.1	None			Approved	9/9/2017
ePortal 1.5	libxpdf 5.1.2 (AGPL-3.0)	P1 - High	① libxpdf 5.1.2	① AGPL-3.0	None			Rejected	9/9/2017
ePortal 1.5	libjpeg 6b (Independent JPEG Group License)	P3 - Low	① libjpeg 6b	① IJG	0 0 0 0 3			Ready for Review	9/9/2017
ePortal 1.5	libpng 1.0.6 (Libpng License)	P1 - High	① libpng 1.0.6	① Libpng	1 1 0 0 170			Rejected	2/6/2019
ePortal 1.5	Log4j-Adapters.Hawk 3.1.0 (Apache-2.0)	P3 - Low	① log4j-adapters.hawk 3.1.0	① Apache-2.0	None			Approved	9/9/2017
ePortal 1.5	rails 1.2.4 (MIT)	P3 - Low	① rails 1.2.4	① MIT License	None			Rejected	9/9/2017
ePortal 1.5	scriptaculous 1.8.1 (MIT)	P3 - Low	① scriptaculous 1.8.1	① MIT	None			Approved	9/9/2017
ePortal 1.5	zlib 1.1.3 (Zlib)	P1 - High	① zlib 1.1.3	① Zlib	0 0 0 0 1			Rejected	2/6/2019

Figure 1: Example of a software bill of materials (SBOM)

principle of and need for SBOMs. This executive order drew on wording from the National Telecommunications and Information Administration (NTIA) and its Software Component Transparency project, which have worked to move SBOMs forward. These initiatives made clear the need for anyone selling software to the US government to deliver an SBOM.

This also triggered heightened awareness within the private sector and within regulated industries. For example, some companies, like Scania (part of the Volkswagen Group), now only accept software from their suppliers if an SBOM is provided.

Previously, the European Union had guidance for things like cloud solutions, Internet of Things (IoT), inventory of third party components and libraries, and SBOMs. The executive order raised awareness globally about SBOMs and how they can add value by meeting the requirements of vulnerability disclosure programs. Software companies in India, Europe, or anywhere else are likely selling their software or product to a US customer or the US government and

therefore must be aware of the move towards SBOM usage.

A March 21, 2022, fact sheet from the Biden-Harris Administration highlighted the need for companies to strengthen their cybersecurity initiatives. The need for this comes not only from the growing number of cyberattacks and exploited vulnerabilities (such as Log4j and Spring4Shell), but from the risk of Russia's potential engagement in "malicious cyber activity." Vulnerabilities will continue. It's a matter of when, not if.

A closer look at SBOMs

When an airplane or automobile is built, every component is tracked. An inventory defines exactly which parts, big or small, were used in the manufacturing process. Should a part fail or need to be recalled, it's clear which vehicle is impacted.

That same approach of tracking components applies to the safe development of software. An SBOM provides a list of the ingredients in your software. It inventories all the software

components and dependencies in an application. Minimum elements include data fields, such as name, version, and licence. Predominantly open source, an SBOM also includes all inbound third-party software that's used.

The immense volume of data in an SBOM means that it must be in a machine-consumable format. Relying on a human processor or manual approach isn't viable. The format must be one that both the provider and the consumer of the SBOM can programmatically communicate and interpret, while keeping pace with rapid development cycles.

Today, the software industry is coming together to identify what format that inventory should take, working towards a consistent presentation of SBOMs and for automation support. A standard format will make it easier for software companies and software consumers to build, use, and share the SBOM. Noteworthy industry initiatives include:

- **CycloneDX:** With origins in the Open Web Application Security Project (OWASP) community,